CDRI
Coalition for Disaster Resilient Infrastructure

Data Protection & Privacy Policy



Data Protection & Privacy Policy

Document Control and Approvals

Approved by	Director General	**Approval Date**	25 March 2025
Policy Owner	Director (Operations)	**Policy Delegate**	Information and Technology Unit
Document No.		**Effective Date**	01 April 2025
Status	Internal Use only	**Version**	1.0

Signature

Date

Revision History

#	Version from	Version to	Date of Change	Deletions/ Additions/ Modifications	Approved by
1					
2					
3					

Please note:

This document contains confidential information solely for the use of CDRI only. Unauthorized sharing, copying, or distribution is prohibited.

Policies and procedures are subject to periodic review and revision by management. Changes will be timely communicated. The information in this document is proprietary to CDRI.

Table of Contents

1. Purpose 4
2. Scope 5
3. CDRI sets of Data and Definitions 5
4. Application of Laws and sources of authority 7
5. Principles for Processing Personal Data 8
6. Reasonable Security Safeguards 10
7. Procedure for Audits and Controls 11
8. Data Processing 12
9. Transmission of Personal Data 14
10. Subject Access and Modification requests to Personal Data 15
11. Providing Information 16
12. Confidentiality of Processing 17
13. Confidential Information 17
14. Processing Security 17
15. Violation, Sanction and Reporting 19
16. Complaint Handling and Resolution 19
17. Responsibilities 21
18. Procedure for Maintaining a Record of Processing Activity (ROPA) 23
19. Key Contact(S) 24
20. Changes in Policy 24

Data Protection & Privacy Policy

The Coalition for Disaster Resilient Infrastructure (CDRI), supported by its Secretariat, promotes the rapid development of resilient infrastructure to respond to the Sustainable Development Goal's imperatives of expanding universal access to services and enabling prosperity.

CDRI is committed to international compliance with data protection laws. This Data Protection and Privacy Policy applies worldwide and is based on globally accepted basic data protection principles. Ensuring data protection is the foundation of trustworthy relationships and CDRI's reputation as a credible organization.

CDRI Data Protection and Privacy Policy (the "**Data Protection and Privacy Policy**" or "**Policy**") ensures adequate data protection as prescribed by relevant legal frameworks, including in countries that do not yet have adequate data protection laws.

CDRI Data Protection is designed to be a practical and easily comprehensible document for CDRI Personnel, CDRI Stakeholders, and CDRI Service Providers, who rely heavily on our ability to safeguard all forms of entrusted information. Acknowledging this critical importance, the Operations serves as CDRI's focal point for all matters concerning online information security.

1. Purpose

This Policy aims to ensure that CDRI processes all personal and special categories of information compliantly and in the best interest of individuals. The Policy serves as a critical security protocol to standardize the use, management, and governance of personal data and special categories of information within CDRI with the primary objective of protecting and securing all data that CDRI handles, stores, or processes.

CDRI may receive, collect, store, and/or use Personal Information from or related to an Individual (as defined in Section 3), including – but not limited to – Personal Information from CDRI Personnel, CDRI Stakeholders, CDRI Service Provider, or other people the CDRI has a relationship with or may need to contact. This Policy sets out the data protection and privacy principles and standards applicable to Personal Information processed by the CDRI.

This Policy has been established to help ensure that CDRI:

- Takes into account the rules and good practices of other international organizations on data protection and privacy, as well as all relevant human rights and fundamental freedoms of an Individual, in particular, their right to privacy;
- has internal administrative procedures that are aligned with high standards of data protection while recognizing and safeguarding CDRI's special status privileges and immunities;
- is open and transparent about how it stores and processes Individuals' data;
- protects against the risks of a data breach.

2. Scope

This Data Protection and Privacy Policy applies to all Personal Information (as defined in Section 3 of this Policy) held at any time by the CDRI, in any form and processed manually or automatically, and wherever located.

This Policy applies to Personal Information held by the CDRI and relating to any Individual, including, but not limited to, CDRI Personnel, CDRI Stakeholders, CDRI Service Providers (as defined in Section 3), and other people the CDRI has a relationship with or may need to contact ("Third Parties"). This Policy may also apply to any person employed by an entity that carries out any assignment/projects/tasks for CDRI.

3. CDRI sets of Data and Definitions

CDRI Data Protection and Privacy Policy encompasses all sets of informational data stored, maintained, and managed by CDRI, with a specific focus on the following identified sets of personal data including the terms used in this Policy:

3.1 "CDRI Personnel" means national and international employees, consultants, interns, young fellows, project-based, outsourced staff, advisors, consultants, and technical experts of the CDRI, and/ or any other Individual engaged by the CDRI to perform official functions for the CDRI.

3.2 "CDRI Service Providers" denotes CDRI's contractors, vendors, suppliers, agencies and implementing partners, etc.

3.3 "CDRI Stakeholders" represent CDRI's partners, member countries, direct and indirect beneficiaries, grantees, donors, trust fund, prospective employees and/or any other organization associated with CDRI.

3.4 "Consent" would mean a consent given by an Individual which is free, specific, informed, unconditional and unambiguous with a clear affirmative action. This Consent shall signify an agreement to the processing of their Personal Information for the specified purpose and be limited to such Personal Information as is necessary for such specified purpose.

- *Explanation*: Here "Specified Purpose" means the purpose mentioned in the notice given by CDRI to the Individual in accordance with applicable laws.

3.5 "Data Controller" or "Data Owner" or "Data Fiduciary" means any authorized personnel/authority that determines the purposes and means of processing Personal Data. The Data Controller is responsible for ensuring that Personal Data is processed in compliance with applicable data protection laws and regulations.

"Processing" of Personal Information shall mean any operation or set of operations that is performed on Personal Information, whether by automatic means, such as collection, recording, organization, storage, adaptation, alteration, maintenance, retrieval, access, consultation, use, transfer, transmission, and dissemination, or otherwise making available, alignment or combination, blocking, erasure or destruction; and

3.6 "Data Protection Officer" (hereinafter referred to as "DPO") means a member of CDRI Personnel and is appointed to be responsible for overseeing CDRI's data protection framework and its implementation to ensure compliance with the Data Protection Policy and shall be the point of contact for redressal of the grievances. The official designated by the Director of Operations will serve as CDRI's Data Protection Officer (DPO).

3.7 "Individual" means any identified or identifiable person; is one who can be identified, directly or indirectly, basis the Personal Data;

3.8 "Personal data/information"

a. Means any information that relates to an Individual which, if disclosed, would affect the legitimate privacy interest of the Individual concerned, regardless of whether the information was released by itself or in combination with additional information that would make it possible to identify the Individual;

b. In the context of this Policy, Personal data will also include "Sensitive Personal Information" which means information about the Individual's race or ethnic origin; opinions; beliefs; facts including offences, criminal convictions and history; trade union memberships; health including data concerning her/his sex life or sexual orientation; and the processing of genetic and/or biometric data that uniquely identifies the Individual.

4. Application of Laws and sources of authority

CDRI is an international organization with its Secretariat based in New Delhi, India. As part of its commitment to best practices, CDRI adheres to Indian laws, including the DIGITAL PERSONAL DATA PROTECTION ACT, 2023 and its associated rules (hereinafter referred to as the Data Protection Act, the "DPA"), as well as the General Data Protection Regulation (GDPR) (EU) 2016/679. The GDPR, which was approved by the European Commission in April 2016, has been in effect for all EU Member States since May 25, 2018.

CDRI Data Protection and Privacy Policy comprises the internationally accepted data privacy principles without replacing the existing national laws. It supplements the national data privacy laws. The relevant national law will take precedence in the event that it conflicts with this Data Protection and Privacy Policy, or it has stricter requirements than this Policy. The content of this Data Protection and Privacy Policy must also be observed in the absence of corresponding national legislation. The reporting requirements for data processing under national laws must be observed. Each entity of CDRI, including network and branch offices (if any), is responsible for compliance with this Data Protection and Privacy Policy and its legal obligations.

In the event of conflicts between national legislation and the Data Protection Policy, CDRI will work with the relevant country offices to find a practical solution that meets the purpose of the Data Protection Policy.

5. Principles for Processing Personal Data

CDRI shall treat Personal Information entrusted to them in a way that respects the privacy of the Individual subject to limits and restrictions set out herein.

5.1 Fairness and Lawfulness

- When processing Personal Data, the individual rights of the Data Subjects must be protected. Personal Data must be collected and processed in a legal and fair manner.
- CDRI shall give a written notice either with or before making any requests to an Individual for Consent for Processing Personal Data/Information. This notice shall contain the following details:
  - That Personal Data is being Processed.
  - Purpose for Processing the Personal Data.
  - The manner in which the Individual may:
    - Exercise their rights under the Policy.
    - Withdraw consent easily, in a manner comparable to the process of giving consent.
    - File a complaint with the Data Protection Officer (DPO).
- Collected Personal Data shall be adequate, relevant and not excessive in relation to the purposes for which they are obtained and their further processing.
- Individual Personal Data can be Processed upon receipt of prior Consent from the respective Individual to whom the Personal Data relates to.

5.2 Restriction to a specific purpose

- Personal Data can be Processed only for the purpose that was defined in the written notice issued before or at the time the Personal Data was collected. Personal Data shall be obtained for specified, explicit and legitimate purposes, and shall not subsequently be processed in a manner that is incompatible with those purposes. Subsequent changes to the purpose are only possible to a limited extent and require justification and fresh consent from the Individual.
- However, further data processing for statistical, scientific, and historical purposes shall be considered compatible with the initial purposes of the data collection if it is not used to make decisions regarding the Individual.

5.3 Transparency

- The Individual must be informed of how their data is being handled. In general, Personal Data must be collected directly from the Individual concerned. When the data is collected, the Individual must either be made aware of, or informed of:
  - The purpose of data processing.
  - Categories of third parties to whom the data might be transmitted for Processing purposes.
- Processing of Personal Data must be accompanied with the Consent of the Individual or must meet one of the following lawful bases: (i) compliance with any legal obligation to which CDRI is subject; protection of the Individual's life or anyone else's life; performance of a public service mission entrusted to CDRI.

5.4 Confidentiality and Data Security

Personal Data is subject to data secrecy. It must be treated as confidential on a personal level and secured with suitable organizational and technical measures to prevent unauthorized access, illegal processing or distribution, and accidental loss, modification, or destruction.

5.5 Retention and Disposal

Personal Data shall be retained in a form that allows the identification of the Individual for a period no longer than is necessary for the purposes for which they are obtained and processed and subject to the domestic laws of the respective jurisdiction, this may be removed on a request generated by the concerned individual. There may be an indication of interests that merit protection or historical significance of this data in individual cases. If so, the data must remain on file until the interests that merit protection have been clarified legally or the organization archive has evaluated the data to determine whether it must be retained for historical purposes. Any exception shall require the recommendation of DPO (as defined in Section 3) and approval from the Director Operations.

5.6 Factual Accuracy and Up-to-datedness of Data

Personal Data on file must be correct, complete, and – if necessary – kept up to date. Suitable steps must be taken to ensure that inaccurate or incomplete data are deleted, corrected, supplemented or updated subject to compliance of Section 5.7.

5.7 Right to correction and erasure of Personal Data

An Individual shall have the right to correction, completion, updating and erasure of his/her Personal Data for the Processing of which he/she has previously given the Consent. In case CDRI has appointed a third party Data Processor, in such instance where Individual has requested for erasure of his/her Personal Data or the purpose for which the Personal Data was collected is no longer served, then as soon as it is reasonable, the Data Fiduciary shall instruct the Data Processor to erase any Personal Data that was made available by the Individual for processing to such Data Processor. Data Fiduciary shall ensure that such erasure is successfully carried out by the Data Processor.

5.8 Data Anonymization and Deletion

CDRI must ensure that when Personal Data is no longer needed for specified purposes, it should be deleted or anonymized in accordance with the applicable policies.

CDRI will take all reasonable steps to destroy or erase from its systems all Personal Data that is no longer require in accordance with the it's applicable policies. This includes requesting third parties to delete such data where applicable.

6. Reasonable Security Safeguards

CDRI shall follow certain reasonable security safeguards in relation to processing and handling of Personal Data and prevent data breach as below:

- Securing of Personal Data through its encryption, obfuscation, masking or password protection;
- Appropriate measures to control access to the information resources used by such Data Owner, Data Processor or Data Fiduciary;
- Visibility on the accessing of such Personal Data, through appropriate logs, monitoring and review, for enabling detection of unauthorized access, its investigation and remediation to prevent recurrence;
- Reasonable measures for continued processing in the event of confidentiality, integrity or availability of such Personal Data being compromised as a result of destruction or loss of access to Personal Data or otherwise, including by way of data backups;

- For enabling the detection of unauthorized access, its investigation, remediation to prevent recurrence and continued processing in the event of such a compromise, retain such logs and Personal Data for a period of one year;
- Appropriate provision in the contract entered into between such Data Fiduciary and such a Data Processor, as may be applicable, for taking reasonable security safeguards;
- Appropriate technical and organizational measures to ensure effective observance of security safeguards.

Procedure for Audits and Controls

6.1 Planning and Scheduling Audits:

- The Data Protection Officer (DPO) will develop an annual audit plan, which includes scheduled internal and external audits of data protection practices.
- Audits will be conducted at least once a year, with additional audits scheduled as needed based on risk assessments or incidents.

6.2 Audit Scope and Objectives:

- The scope of each audit will be defined based on specific objectives, including:
  - Compliance with data protection laws and regulations.
  - Adherence to internal data protection procedures.
  - Evaluation of Processing activities, data security measures, and record-keeping practices.
  - The objectives will be aligned with CDRI's goals and regulatory requirements.

6.3 Preparation for Audits:

- Prior to the audit, the DPO will notify relevant units and stakeholders about the audit schedule and scope.
- Necessary documents, records, and evidence will be gathered and prepared for review.
- An audit team, comprising internal or external auditors with relevant expertise, will be appointed.

6.4 Conducting Audits:

- The audit team, as appointed, will conduct a thorough examination of data protection practices, including:

- Reviewing policies, procedures, and documentation.
- Inspecting physical and digital security measures.
- Interviewing CDRI Personnel and Stakeholders involved in data processing activities.
- Any non-compliance or potential risks identified during the audit will be documented in an audit report.

6.5 Audit Reporting:

- The audit team will prepare a comprehensive audit report, detailing findings, observations, and recommendations.
- The report will be reviewed by the DPO and shared with Director Operations.
- The DPO will ensure that the report includes actionable steps for addressing identified issues.

6.6 Follow-Up Actions:

- The DPO will develop corrective action plan based on the audit findings and recommendations.
- Units involved will be responsible for implementing corrective measures within specified timelines.
- The DPO will monitor progress and ensure that all actions are completed effectively.
- The DPO will report the closure of all the corrective action plans to the Director Operations.

6.7 Documentation and Record Keeping:

- All audit reports, corrective action plans, and related documentation will be maintained by the DPO.
- Records of audits will be retained for a minimum of 8 years for reference and regulatory purposes.
- Documentation will include details of audit schedules, findings, actions taken, and follow-up results.

7. Data Processing

7.1 Consent to Data Processing

Every request for Consent shall be presented to the Individual in a clear and plain language, giving him/her the option to access such request in English or any other official language of the member countries recognized by CDRI.

Personal Data can be processed upon Consent of the Individual concerned. Declarations of Consent must be submitted voluntarily by the Individual concerned.

An Individual shall have the right to withdraw his/her Consent at any time, with the ease of doing so being comparable to the ease with which such Consent was given. The consequences of the withdrawal of Consent shall be borne by the Individual.

CDRI may engage, appoint, use or otherwise involve a Data Processor to process Personal data under a valid contract.

7.2 Data Processing Pursuant to Legitimate Interest

Personal Data can also be processed if it is necessary to enforce a legitimate interest of CDRI. Legitimate interests are generally of a legal nature (such as filing, enforcing, or defending against legal claims), audit, or financial nature. Personal Data may not be processed based on a legitimate interest if, in individual cases, there is evidence that the interests of the Individual merit protection.

Before data is processed, it must be determined whether there are interests that merit protection. Control measures that require the Processing of Personal Data can be taken only if there is a legal obligation to do so or there is a legitimate reason. Even if there is a legitimate reason, the proportionality of the control measure must also be examined.

7.3 Telecommunications and Internet

CDRI provides IT equipment, e-mail addresses, intranet and internet access, and internal social networks primarily for work-related assignments. These are tools and organizational resources that can be used within the applicable legal regulations and internal CDRI IT policy and procedures. In the event of authorized use for private purposes, the laws on secrecy of telecommunications and the relevant national telecommunication laws, e.g. Indian Laws like The Information Technology Act, 2000 (IT Act) and allied rules and regulations, including The Information Technology (Intermediary Guidelines and Digital Media Ethics Code) Rules, 2021,Telecom Regulatory Authority of India Act, 1997 (TRAI Act) and allied Rules, The Right to

Information Act, 2005 (RTI Act) and allied Rules, sector specific regulations, etc. must be observed as applicable.

7.2 Rights of the Individual

All Individuals who are the subject of Personal Data held by CDRI are entitled.

- To request information on which personal data relating to Individual has been stored, how the data was collected, and for what intended purpose. If there are further rights to view the employer's documents (e.g. personnel file) for the employment relationship under the relevant employment laws, these will remain unaffected. If Personal Data is transmitted to third parties, Individuals should be informed of such a possibility by way of clear notice (the conditions under Section 5.1).
- To request employee data to be deleted if the Processing of such data has no legal basis, or if the legal basis has ceased to apply. The same applies if the purpose behind the data processing has lapsed or ceased to be applicable for other reasons. Existing retention periods and conflicting interests meriting protection must be observed.
- To object to Individual's data being processed, and this must be taken into account if the protection of Individual's interests takes precedence over the interest of the data controller owing to a particular personal situation. This does not apply if a legal provision requires the data to be processed.

8. Transmission of Personal Data

- Transmission of Personal Data to recipients outside or inside CDRI is subject to the authorization requirements for Processing Personal Data under Section 8 and requires the Consent of the Individual. The data recipient must be required to use the data only for the defined purposes.
- In the event that data is transmitted to a recipient outside CDRI, this recipient must agree to maintain a data protection level equivalent to this Data Protection and Privacy Policy. This does not apply if transmission is based on a legal obligation.
- The Processing of Personal Data is also permitted if national legislation requests, requires or authorizes this. The type and extent of data processing must be necessary for the legally authorized data processing activity and must comply with the relevant statutory provisions. If there is some legal flexibility, the interests of the Individual that merit protection must be taken into consideration. The Processing of Personal Data from a legitimate standpoint

requires the recommendation of DPO and approval from the Director Operations.

- In certain circumstances, the CDRI Data Protection and Privacy Policy allows Personal Data to be disclosed, based on a legal obligation, to law enforcement agencies without the Consent of the Individual.
- Director Operations can validate any such disclosure in writing, ahead of the disclosure, after ensuring the request is legitimate, motivated by the requester, appropriate, necessary and does not pose a threat or direct risk to CDRI.
- Before approving such disclosure, the concerned data management personnel/team in consultation with CDRI DPO will check that the recipient of the data uses the data for the defined purposes only and that it demonstrates the capacity and will to abide by such an obligation. The disclosure of data will require the recommendation of DPO and the approval of Director Operations.
- Where necessary, CDRI's Director Operations will refer to legal advisers for advice, and to CDRI's Committee for validation, notably but not only in cases involving direct security threats and implications or global organizational risks including reputation.

9. Subject Access and Modification requests to Personal Data

All CDRI Personnel, Stakeholders and Service Providers (as defined in Section 3) can contact CDRI to request that the rights listed in Section 8 .4—Rights of the Individual be applied.

Access requests from Individuals should be addressed by email or in writing. If not in writing, the request should be taken and handled by DPO and registered in a log for reference and follow-up.

Any Individual subject access request received by CDRI will be duly verified before being handled, and the identity of anyone making a subject access request will be verified before any information is handed over.

CDRI will ensure that individual requests are responded within 30 working days.

CDRI will ensure that any Individual—including, but not limited to, CDRI Personnel, Stakeholders, Service Providers, or any other organizations associated with CDRI—has the means to contact CDRI to verify the data held about them. They will also have the ability to request authorized CDRI Personnel to update, complete, or correct their personal information. This obligation includes the following:

- CDRI Personnel should have access to their personal files and any information CDRI holds on them, by simple request to the Human Resources unit, to be presented and approved by DPO only. The consultation of any information on any other personnel is strictly prohibited.
- CDRI Stakeholders shall check the data that CDRI holds on them, to ensure its correctness, completeness and fairness, and to have it modified and updated upon request by duly authorized CDRI personnel. For such a purpose, CDRI should set up and maintain a complaints response mechanism that is open and accessible to Individuals, with limited constraints, while ensuring that any request by Individuals is duly followed by appropriate corrective measures and communications. Contact information to uphold this right and reach out to CDRI for such a purpose should be clearly indicated on CDRI website and other means of public information.
- CDRI Service Providers can contact CDRI to check and correct or complete data held by CDRI. The designated DPO have such a responsibility, with due approval from Director Operations.
- CDRI Service Providers shall have access to review any data that CDRI holds on them to ensure its accuracy and fairness. They can request modifications and updates as needed.

10. Providing Information

CDRI aims to ensure that Individuals are aware that their data is being processed, and that they understand:

- How the data is being used.
- How to exercise their rights.

To these ends, the current Policy is shared with all CDRI personnel and is available upon request by Individuals.

Any subscriber or user of an electronic communication service shall be informed clearly and comprehensively by CDRI, except if already previously informed, regarding: the purpose of any action intended to provide access, by means of electronic transmission, to information previously stored in their electronic connection terminal device, or to record data in this device; the means available to them to object to such action.

11. Confidentiality of Processing

Personal Data and Sensitive Information are subjected to data secrecy. Any unauthorized collection, processing, or use of such data by CDRI Personnel is prohibited. Any data processing undertaken by a CDRI personnel that he/she has not been authorized to carry out as part of their legitimate duties is unauthorized. The "need to know" principle applies. DPO may have access to personal information only as is appropriate for the type and scope of the task in question. This requires a careful breakdown and separation, as well as implementation, of roles and responsibilities.

Employees are forbidden to use Personal Data for private or commercial purposes, to disclose it to unauthorized persons, or to make it available in any other way. Reporting managers must inform their team at the start of the employment relationship about the obligation to protect data secrecy. This obligation shall remain in force even after employment has ended.

12. Confidential Information

CDRI is dedicated to ensuring the highest standards of confidentiality when handling sensitive information related to partner organizations. We recognize the importance of safeguarding proprietary and confidential data shared with us by other organizations. This information will be protected from unauthorized access, disclosure, or misuse through stringent confidentiality protocols. Only personnel with proper authorization and a legitimate need to know will have access to such information. Robust technical and organizational measures, including encryption, access controls, and regular security audits, are in place to ensure the security of confidential company data. Any breach of these protocols will be addressed with immediate and appropriate disciplinary action. Our commitment to protecting the confidential information of partner organizations is fundamental to maintaining trust and fostering strong collaborative relationships.

13. Processing Security

Personal Data must be safeguarded from unauthorized access and unlawful processing or disclosure, as well as accidental loss, modification or destruction. This applies regardless of whether data is processed electronically or in paper form. Before the introduction of new methods of data processing, particularly new IT systems, technical and organizational measures to protect personal data must

be defined and implemented. These measures must be based on the state of the art, the risks of processing, and the need to protect the data (determined by the process for information classification). The technical and organizational measures for protecting Personal Data are part of CDRI management and must be adjusted continuously to the technical developments and organizational changes.

14. Violation, Sanction and Reporting

Any failure to comply with the current Policy or to deliberately violate the rules set in the Policy will result in the launch of an appropriate investigation by CDRI.

Depending on the gravity of the suspicion or accusations, CDRI may suspend the Personnel or relations with other Stakeholders during the pendency of investigation. This will not be subject to challenge.

Depending on the outcome of the independent investigation, if it comes to light that anyone associated with CDRI has deliberately violated the rules set in the Policy for their personal profit or any other usage of Personal Data, or has systematically and deliberately contravened with the principles and standards contained in this Policy, CDRI will take immediate disciplinary action and any other action which may be appropriate to the circumstances and the applicable laws.

Depending on the nature, circumstances and location of the case and violation, CDRI will also consider involving authorities such as the police to ensure the protection of personal data and victims.

The reporting of suspected or actual violations of this Policy is a professional and legal obligation of all CDRI Personnel, Stakeholders and Service Providers. Failure to report information can lead to disciplinary action.

CDRI encourages its Personnel, Stakeholders and Service Providers to report suspected cases that involve any CDRI personnel, consultants, guests or personnel of CDRI's partner organizations, their board members, personnel and or suppliers. CDRI requires its Personnel, Stakeholders and Service Providers to report suspected cases by contacting DPO email ID i.e. (**DPO@cdri.world**) or through an online portal Ethics Point.

All reports will be treated as confidential in line with CDRI's Code of Conduct.

Anyone found making false accusations will be subject to investigation and disciplinary action.

15. Complaint Handling and Resolution

- Receipt of Complaints:

- All complaints regarding the Policy violation(s) must be directed to the Data Protection Officer (DPO) via the dedicated email address.
- Complaints can be submitted by any person including CDRI Personnel, Stakeholder, Service Providers, Third Parties.

- Acknowledgment of Complaints:
  - The DPO must acknowledge receipt of the complaint within 2 working days.
  - The acknowledgment should include information about the next steps and the expected timeline for resolution.
- Initial Assessment:
  - The DPO will conduct an initial assessment of the complaint to determine its validity and severity.
  - If the complaint is deemed invalid, the DPO will notify the complainant, providing a clear explanation.
- Investigation:
  - For valid complaints, the DPO will initiate a thorough investigation, which shall be conducted within three working days.
- Resolution Plan:
  - Based on the investigation findings, the DPO will develop a resolution plan, which may include:
  - Corrective actions to address any violation of the Policy.
  - Measures to prevent recurrence.
  - Recommendations for disciplinary action in case of Policy breach.
  - The resolution plan will be reviewed and approved by CDRI's Director Operations.
- Communication of Resolution:
  - The DPO will communicate the resolution plan to the complainant, including the actions taken and any changes implemented.
  - The complainant will be informed of their right to escalate the issue to a regulatory authority, if any, if they are not satisfied with the resolution.
- Implementation of Actions:
  - The DPO will oversee the implementation of the corrective actions and ensure they are completed within the specified timeframe.
  - Units involved in the complaint will be responsible for executing the required actions.

16.Responsibilities

16.1 Data Owner/ Controller / CDRI/ Data Fiduciary/ Data Processor:

- CDRI is responsible for ensuring that the legal requirements, and those contained in this Data Protection Policy, for data protection, are met (e.g., national reporting duties).
- The DPO, in consultation with the Director of Operations, is responsible for ensuring that appropriate operational and technical measures are in place so that any data processing is carried out in accordance with the Policy and the applicable laws. Reporting managers must ensure that their team is sufficiently trained in data protection.
- Compliance with these requirements is the responsibility of the relevant CDRI Personnel.
- CDRI shall ensure that all CDRI Personnel receive comprehensive training relevant to their roles and responsibilities within the organization.
- This includes, but is not limited to, providing comprehensive training sessions on data privacy principles, the handling of Personal Data, CDRI's Policy, and the legal requirements under applicable data protection laws such as the DPA and GDPR.
- Additionally, CDRI must implement assessment tools to evaluate the effectiveness of the training programs and ensure that CDRI Personnels understand and adhere to data protection practices. This proactive approach is essential to maintaining compliance and safeguarding the Personal Data entrusted to CDRI.
- In the event of a Personal Data breach, the Data Fiduciary shall notify the Director Operations and each affected individual in the prescribed form and manner.

16.2 Data Protection Officer

The primary responsibilities of the DPO shall be as follows:

- Advising on Compliance Obligations:
  - Informing and advising the CDRI and CDRI Personnel about their obligations under all applicable data protection laws.
  - Providing guidance on data protection impact assessments (DPIAs) as per the applicable laws and monitoring their performance.
  - Ensuring that the data is accurate, complete and up-to-date.
- Monitoring Compliance:
  - Overseeing the implementation of the Policy and practices.
  - Conducting quarterly audits and assessments to ensure ongoing compliance.

- Ensuring that the organization's data processing activities align with relevant regulations and policies.

- Training and Awareness:
  - Helping CDRI develop and deliver data protection training programs for staff.
  - Raising awareness about data protection principles and practices across the organization.
- Individual Rights:
  - Facilitating the exercise of Individual rights, such as access, rectification, erasure, and data portability.
  - Responding to Individual requests in a timely and appropriate manner.
- Data Breach Management:
  - Acting as the first point of contact for data breach notifications and investigations.
  - Coordinating the response to data breaches, including containment, assessment, and reporting to supervisory authorities and affected Individuals when required.
- Communication with Authorities:
  - Serving as the liaison between the organization and data protection authorities.
  - Ensuring that the organization cooperates with regulatory authorities during investigations or audits.
- Record-Keeping:
  - Maintaining records of data processing activities, including the purposes of processing, categories of Individuals, and data sharing arrangements by creating processes with the all the units in the organisation.
  - Documenting and maintaining evidence of compliance efforts and decisions made in relation to data protection.
- Policy Development and Review:
  - Assisting in the development, implementation, and maintenance of data protection policies and procedures.
  - Regularly reviewing and updating data protection policies to reflect changes in laws, regulations, and best practices.

- Risk Management:
  - Formulating and establishing processes to identify and assess data protection risks within the organization and giving solutions to mitigate the risks accordingly.
  - Recommending and implementing measures to mitigate identified risks.

17. Procedure for Maintaining a Record of Processing Activity (ROPA)

17.1 Identify Data Processing Activities:

- All units must identify and document their data processing activities, specifying the purpose of each activity and the types of personal data involved.
- A person should be designated within each unit to oversee this task.
- Document the ROPA.
- Use the standardized ROPA template provided by the Data Protection Officer.
- Include the following information for each processing activity:
  - Name and contact details of the data processor.
  - Purpose of processing.
  - Description of the categories of Individuals and Personal data.
  - Categories of recipients to whom the personal data have been or will be disclosed.
  - Details of transfers to foreign countries, including documentation of the transfer mechanism safeguards.
  - Expected retention period for each data category.
  - Description of the technical and organizational security measures in place.

18. Key Contact(S)

For any clarifications on any of the points mentioned in this document, please contact

Primary Contact	Data Protection Officer	dpo@cdri.world
Secondary Escalation	Director Operations	director.ops@cdri.world
Top Escalation	Director General	dg@cdri.world

19. Changes in Policy

While every effort is made to keep the contents of this Policy current, CDRI reserves the right to modify, suspend, or terminate any of the policies (and the procedures, standards, and guidelines as accompaniments) with or without prior notice to CDRI Personnels, Stakeholders or Service Providers.

Any exception to the Data Protection and Privacy Policy shall require approval from the Director Operations. The concerned employee must obtain this approval through their reporting manager.

CDRI

Coalition for Disaster Resilient Infrastructure

4th & 5th Floor, Bharatiya Kala Kendra,
1, Copernicus Marg, New Delhi 110001, India

communication@cdri.world

www.cdri.world

@cdri_world

@coalition-for-disaster-resilient-infrastructure